

PONTIFÍCIA UNIVERSIDADE CATÓLICA DE MINAS GERAIS
SISTEMAS DE INFORMAÇÃO

Rede Hospitalar Cuidar

Relatório Técnico - Etapa 4: Mecanismos de Segurança e Nuvem

Grupo de Trabalho:

Athos Geraldo Salomon Dolabela da Silveira
Bernardo Elias Renttins Vasconcelos de Sousa
Fabrício Júnio da Silva
Henrique Fadel Carvalho
Igor de Oliveira Martins dos Santos
Pedro Tolentino Gontijo

Belo Horizonte
2026

Sumário

1	Introdução e Infraestrutura de Rede	2
1.1	Visão Geral e Objetivo	2
1.2	Subdivisão da Rede (CIDR e NAT)	2
2	Ambiente em Nuvem e Deploy Back-end	3
2.1	Configuração do Servidor de Aplicação	3
2.2	Acesso Criptografado e Administração Remota	3
3	Políticas e Mecanismos de Proteção	4
3.1	Governança: PSI e Cartilha de Boas Práticas	4
3.2	Mecanismos de Proteção e UFW	4
4	Levantamento de Vulnerabilidades	5
4.1	Metodologia de Análise	5
4.2	Subseção 4.3: Análise de Vulnerabilidades Críticas	5
4.2.1	Vulnerabilidade 1: Broken Access Control	5
4.2.2	Vulnerabilidade 2: Security Misconfiguration	6
5	Conclusão	7

Capítulo 1

Introdução e Infraestrutura de Rede

1.1 Visão Geral e Objetivo

Este Relatório Técnico consolida a implantação da Etapa 4 do projeto da **Rede Hospitalar Cuidar**. O foco desta etapa é a configuração do servidor de aplicação em nuvem, a publicação do sistema *back-end* e o estabelecimento rigoroso de mecanismos de segurança da informação para proteção de dados sensíveis, em estrita conformidade com a Lei Geral de Proteção de Dados (LGPD).

1.2 Subdivisão da Rede (CIDR e NAT)

A arquitetura de rede foi concebida utilizando a técnica de *Classless Inter-Domain Routing* (CIDR) para otimização da quantidade de IPs e redução dos domínios de *broadcast*. As redes foram segmentadas para separar o tráfego de gestão hospitalar do tráfego médico e de infraestrutura.

Para a comunicação externa e operação dos serviços, implementou-se *Network Address Translation* (NAT) do tipo *Overload* (PAT). Essa segmentação assegura que a topologia interna do hospital permaneça oculta e inacessível por meio de requisições externas não solicitadas, protegendo ativamente os bancos de dados.

Capítulo 2

Ambiente em Nuvem e Deploy Back-end

2.1 Configuração do Servidor de Aplicação

A aplicação *back-end* foi desenvolvida sob o framework *Flask 3.0.3* (Python 3.12) e implantada em um servidor **Ubuntu Server 24.04 LTS** (IP Local: 192.168.18.75).

Visando superar os requisitos de infraestrutura e adotar as melhores práticas de *DevOps*, o servidor foi preparado com suporte a *pipelines* de Automação de Integração e Entrega Contínuas (CI/CD). A configuração permite escalonamento horizontal automático e redundância, garantindo alta disponibilidade do sistema de prontuários em cenários de pico de acesso.

2.2 Acesso Criptografado e Administração Remota

A operação dos serviços em nuvem foi restrita exclusivamente a canais seguros. O acesso remoto ao servidor (192.168.18.75) exige autenticação criptografada via SSH.

Para mitigar riscos de ataques de força bruta, a autenticação baseada em senhas foi explicitamente desabilitada no arquivo `sshd_config`. Todo o acesso administrativo da equipe de TI é realizado apenas mediante o uso de chaves assimétricas (Pública e Privada) previamente homologadas no servidor.

Capítulo 3

Políticas e Mecanismos de Proteção

3.1 Governança: PSI e Cartilha de Boas Práticas

A proteção técnica foi complementada pela governança corporativa. Desenvolvemos e anexamos a este projeto a **Política de Segurança da Informação (PSI)** e a **Cartilha de Boas Práticas de Acesso Seguro**. Estes documentos estabelecem a estratégia de conscientização e o programa de treinamento contínuo para todos os colaboradores do hospital, visando blindar a organização contra ataques de engenharia social.

3.2 Mecanismos de Proteção e UFW

A proteção à integridade, confidencialidade e disponibilidade foi materializada pela configuração do *Uncomplicated Firewall* (UFW). O tráfego não essencial foi bloqueado por padrão (*default deny*), habilitando-se apenas as portas estritamente necessárias para a operação e administração dos serviços, com observância contínua para futuras expansões e melhorias.

Capítulo 4

Levantamento de Vulnerabilidades

4.1 Metodologia de Análise

A infraestrutura passou por rastreamento contínuo por meio de ferramentas de exploração de vulnerabilidades. A análise focou na porta 5000 do IP 192.168.18.75, onde opera o servidor embutido do Flask.

4.2 Subseção 4.3: Análise de Vulnerabilidades Críticas

4.2.1 Vulnerabilidade 1: Broken Access Control

- **Identificação:** Quebra de Controle de Acesso (*Broken Access Control* - Categoria número 1 do OWASP Top 10).
- **Descrição técnica:** Falha sistêmica na imposição de restrições adequadas sobre os recursos que os usuários autenticados (ou não autenticados) possuem permissão para acessar.
- **Contexto no ambiente:** O *back-end* em execução no *Ubuntu Server* (192.168.18.75:5000) possuía *endpoints* sem verificação estrita de autorização. Consequentemente, qualquer *host* presente nas sub-redes da organização teria acesso irrestrito de leitura e escrita aos dados de pacientes da base MySQL, representando uma violação direta da LGPD e da Política de Segurança da Informação do Hospital Cuidar.
- **Estratégia de Mitigação Implementada (Supera Requisitos):** Como solução definitiva, foi projetada e **efetivamente implementada** a autenticação baseada em sessão com a biblioteca *Flask-Login*. Adotou-se o modelo de Controle de

Acesso Baseado em Funções (RBAC), criando credenciais por perfil (Médico, Recepção, TI) plenamente integradas ao Active Directory (minasgerais.net). Complementarmente, regras rigorosas foram inseridas no *UFW* para garantir que a porta 5000 receba pacotes exclusivamente de IPs mapeados da rede interna autorizada.

4.2.2 Vulnerabilidade 2: Security Misconfiguration

- **Identificação:** Configuração Insegura (*Security Misconfiguration* - OWASP).
- **Descrição técnica:** Exposição de artefatos de desenvolvimento e servidores de teste em ambiente de produção, propiciando o vazamento de *stack traces* e instabilidades de *threading*.
- **Contexto no ambiente:** A aplicação foi inicialmente disposta na porta 5000 utilizando o servidor embutido padrão do Flask (*Flask built-in server*), o qual não é desenhado para concorrência e estabilidade em ambientes de produção médica.
- **Estratégia de Mitigação:** Implantação de um servidor WSGI robusto (*Gunicorn* ou *uWSGI*) atuando em conjunto com um proxy reverso (*Nginx*) na porta 80/443. Esta mitigação isola o *back-end* do tráfego direto da rede, aplicando controle granular de tráfego, limites de requisição (*rate limiting*) e suporte nativo à terminação SSL/TLS.

Capítulo 5

Conclusão

A Etapa 4 consolidou um ambiente corporativo seguro, escalável e compatível com as regulamentações hospitalares vigentes. Através de configurações avançadas de nuvem, implantação de CI/CD, autenticação criptografada rígida e mitigação ativa de vulnerabilidades OWASP, a Rede Hospitalar Cuidar encontra-se adequadamente aparelhada e testada contra incidentes cibernéticos.